Sistemas de Comunicación y Seguridad Informática

Semana 8: Pentesting Estructurado

Fases de reconocimiento, escaneo de puertos y análisis de vulnerabilidades.

Docente: Mg. Gabriel Guerrero Arellano



¿Qué haremos en estas 2 horas?

Ubicación en el currículo: Momento 2: Vulnerabilidad y Desarrollo.

Temática: Pentesting Estructurado.

Conceptos Clave: Fases de reconocimiento, escaneo de puertos y análisis de vulnerabilidades.

Herramientas: Docker, Nmap y Nmap Scripting Engine (NSE).

Laboratorio Práctico: Despliegue de un objetivo local y auditoría ofensiva.

Evidencia: Reporte de terminal con puertos y vulnerabilidades detectadas.

Cierre del Momento 2

Seguimos en el **Momento 2: Vulnerabilidad y Desarrollo.**

Ya pasamos por explotación (Semana 5) y desarrollo seguro (Semana 6).

En la Semana 7 vimos automatización. Hoy cerramos este ciclo aprendiendo a buscar metódicamente las brechas de seguridad desde la perspectiva de un atacante ético.



¿Qué es el Pentesting Estructurado?



Es una **auditoría de seguridad ofensiva autorizada.**



No es un "hackeo al azar"; sigue metodologías rigurosas de la industria (como PTES o OSSTMM).



El objetivo es **identificar, clasificar y documentar** brechas de seguridad antes de que un ciberdelincuente real las explote.

El Ciclo de Vida del Ataque



Reconocimiento: Recolección de información pública (pasiva y activa) sobre el objetivo.



Escaneo de Puertos: Interacción directa para descubrir vías de entrada abiertas.



Análisis de Vulnerabilidades: Evaluación del software descubierto en busca de fallos conocidos (CVEs).



Explotación: Ingreso al sistema (lo que vimos en la Semana 5).



Reporte: Documentación detallada para la mitigación.



Tocando las puertas del sistema

Un servidor tiene **65,535 puertos lógicos.**

El escaneo de puertos determina cuáles están abiertos, cerrados o filtrados (protegidos por un firewall).

Descubrir un puerto abierto (ej. 80 para web, 22 para administración SSH) revela qué software exacto se está ejecutando en el servidor.

Buscando la debilidad

01

Una vez que sabemos qué servicios corren en los puertos abiertos, buscamos sus **fallos de seguridad**.

02

Se automatiza mediante motores que comparan la versión del software detectado con bases de datos mundiales de vulnerabilidades.

03

Es el paso crítico previo y necesario antes de intentar cualquier táctica de ataque.

La Cadena de Valor de Hoy

1	2	3	4	5
Preparamos un objetivo (Entorno local).	Realizamos la fase de reconocimiento activa.	Ejecutamos el escaneo de puertos.	Lanzamos el análisis de vulnerabilidades automatizado.	Documentamos los hallazgos como auditores profesionales.



Herramientas a Utilizar

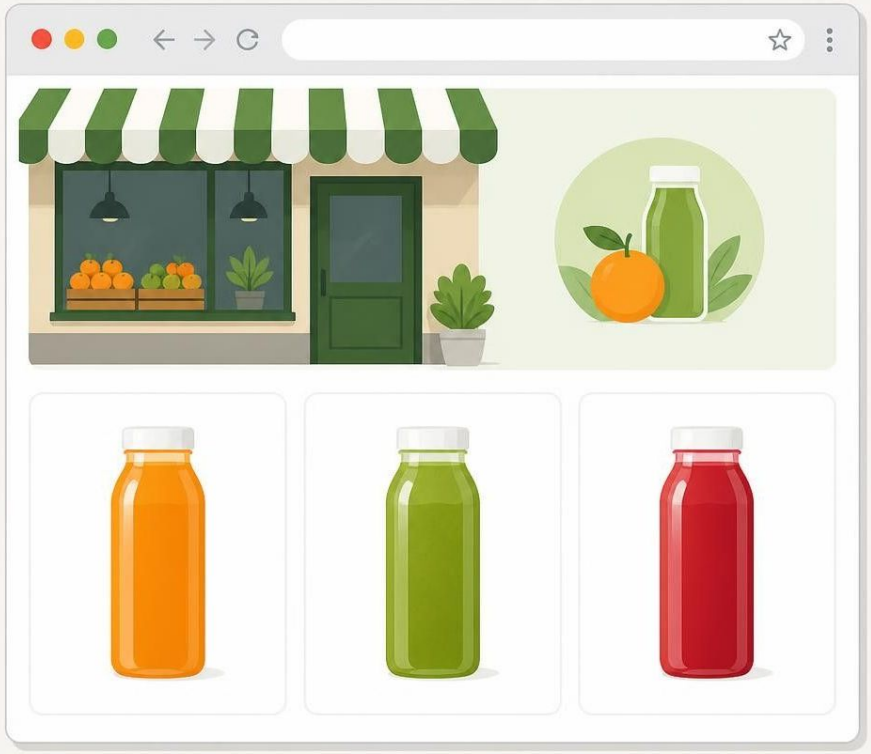
Pasemos de la teoría a la práctica. ¿Qué arsenal utilizaremos para nuestro pentesting de hoy?

El Entorno de Pruebas (Target)

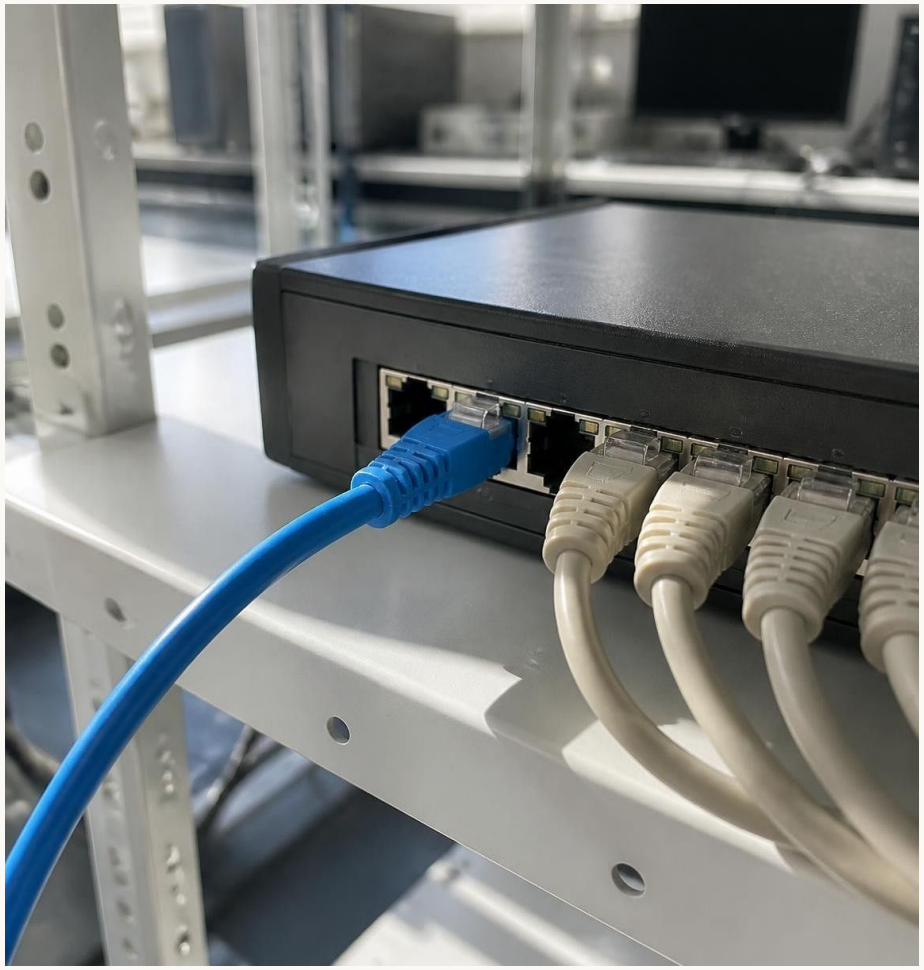
Reutilizaremos Docker (de nuestra sesión de DevSecOps).

Levantaremos una aplicación intencionalmente vulnerable llamada **OWASP Juice Shop**.

Regla de Oro del Pentesting: Es crucial y obligatorio practicar exclusivamente sobre entornos controlados, autorizados y legales.



Nmap (Network Mapper)



El estándar absoluto de la industria para el **escaneo de puertos y reconocimiento.**

Herramienta de línea de comandos que mapea redes y descubre hosts.

Permite escanear con técnicas avanzadas de evasión de firewalls.

NSE: El motor de vulnerabilidades

Es un subsistema de Nmap que permite usar **scripts automatizados.**

Transforma a Nmap de un simple escáner de puertos a una poderosa herramienta de análisis de vulnerabilidades.

Usaremos la categoría de scripts "vuln" para detectar brechas en nuestro servidor local.



Laboratorio Práctico: Auditoría Ofensiva

Objetivo: Levantar un servidor vulnerable local, mapear sus puertos y extraer un reporte de fallos usando la consola.

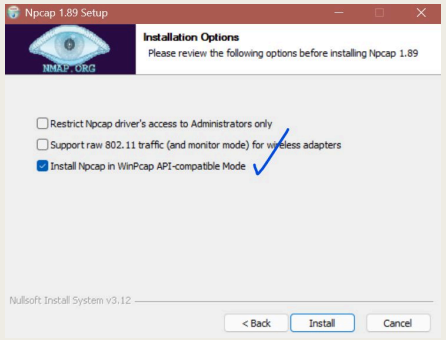


Fase de Validación: Preparando el Entorno Paso a Paso

Atención a todos: No avanzamos hasta que estos comandos funcionen en la terminal (CMD, PowerShell o Bash).

1️⃣ Validar objetivo: `docker --version`

2️⃣ Instalar nmap desde https://nmap.org/download.html#windows



2.1 Validar escáner: `nmap --version`

(Nota: Si no reconocen Nmap, descárguenlo instalador rápido en nmap.org).

3️⃣ Asegurar que el puerto 3000 esté libre (cerrar otras apps).

netstat -ano | findstr :3000

sino arroja nada el puerto esta libre, si esta ocupado saldra LISTENING.

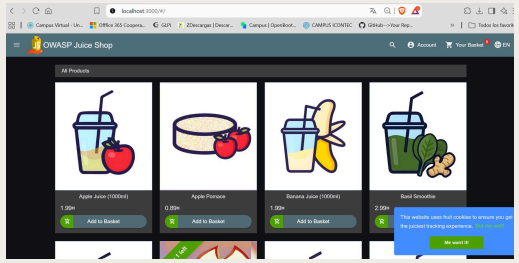
Paso 1: Encendiendo el Target

- Ejecuta este comando en tu terminal para levantar nuestro servidor vulnerable:

```
docker run -d -p 3000:3000 bkimminich/juice-shop
```

Abre tu navegador y entra a: http://localhost:3000

Si ves una tienda web de jugos, tu objetivo está vivo y listo para el reconocimiento.



Paso 2: Escaneo de Puertos Básico

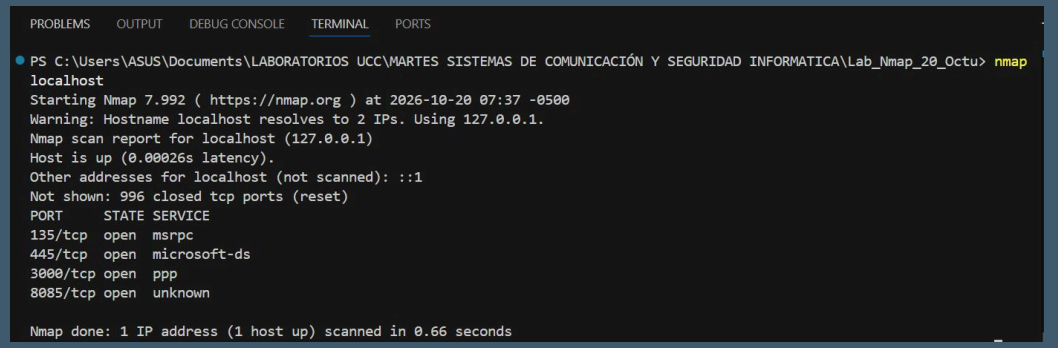
- Abre una *nueva* pestaña en tu terminal (deja la otra quieta).
- Lanza tu primer escaneo hacia tu máquina local:

```
nmap localhost
```

¿Qué hace? Revisa los **1000 puertos más comunes**.

- **Estado del servidor:** El sistema confirmó que el objetivo está activo y responde rápidamente (Host is up).
- **Puertos bloqueados:** De los 1000 puertos más comunes que Nmap revisa por defecto, 996 se encuentran inaccesibles o cerrados (996 closed tcp ports).
- **Puertos abiertos (Vectores de ataque):** Nmap detectó 4 vías de entrada totalmente expuestas:
- 135/tcp y 445/tcp: Son servicios de red nativos y normales de Windows (msrpc y microsoft-ds).
- 8085/tcp: Un puerto abierto por alguna otra aplicación que tienes en segundo plano (unknown).
- **El objetivo del laboratorio:** El puerto 3000/tcp aparece listado como abierto (open). Nmap lo etiqueta superficialmente bajo el protocolo ppp, pero sabemos que ahí es donde reside nuestra aplicación vulnerable (Juice Shop).

Observa en el resultado de la terminal cómo el puerto 3000 aparece como open bajo el servicio tcp.



Paso 3: Descubriendo el Software

- Para el análisis de vulnerabilidades, necesitamos saber qué corre ahí.
- Ejecuta este comando con banderas adicionales:

```
nmap -sV -p 3000 localhost
```



`-sV`: Activa la detección profunda de versiones de software.



`-p 3000`: Le decimos a Nmap que ataque directamente ese puerto para ahorrar tiempo.

- **Enfoque directo:** Al usar la bandera `-p 3000`, Nmap ignoró el resto del sistema y atacó directamente nuestro objetivo.
- **Detección profunda (`-sV`):** El proceso tomó 13.73 segundos en ejecutarse, mucho más que el escaneo rápido anterior, porque Nmap intentó interrogar activamente al servidor.
- **Servicio desconocido (`ppp?`):** Nmap arroja un signo de interrogación en el servicio y deja la columna de versión (VERSION) completamente en blanco. ¡Esta es una excelente lección de pentesting del mundo real! Significa que el contenedor de Docker no está configurado para revelar un "banner" o firma clara con el nombre de su software (como "Apache" o "Node.js"). Nmap no pudo identificarlo con certeza.

Paso 4: Lanzando el arsenal (NSE)

- Llegó la hora de buscar fallos estructurales.
- Ejecuta el escaneo de vulnerabilidades:

```
nmap -sV --script vuln -p 3000 localhost
```



`--script vuln`: Carga todos los scripts ofensivos de la categoría "vulnerabilidades".

Resultados:

- **El escáner actuó "a ciegas":** Como vimos en el paso anterior, Nmap no logró identificar que el puerto 3000 aloja una página web, manteniéndolo etiquetado como `ppp?`.
- **Disparando las armas equivocadas:** Al no saber a qué se enfrentaba, el motor NSE (`--script vuln`) intentó lanzar pruebas genéricas para otros tipos de infraestructuras. Fíjate que intentó ejecutar scripts para servicios RPC (`rpcinfo`, `rpc-grind`) y máquinas virtuales (`vmware-version`).
- **El fallo lógico:** Como nuestra aplicación vulnerable (Juice Shop) es una página web (HTTP/Node.js) y no un servidor de VMware o RPC, los scripts ofensivos de Nmap chocaron contra la pared y fallaron (`Script execution failed`)



Nota: Este paso envía muchas peticiones y puede tardar un par de minutos. ¡El pentesting real toma paciencia!

Anatomía del Ataque: El Valor del Factor Humano

El Mito del "Botón Hacker": Que Nmap no haya arrojado alertas rojas no significa que el sistema sea seguro. Tuvimos un *falso negativo* porque la aplicación ocultó inteligentemente su firma (el famoso ppp?), nmap una herramienta de escaneo de vulenrabilidades de red se quedo corta en escaneo de vulenrabilidades en capa 7 web o aplicación por ello el hacker intenta con otros metodos como SQL injectión.

El Efecto Dominó del Pentesting: Esta es la lección principal de las metodologías. Si la Fase de Reconocimiento no logra identificar el software real, la Fase de Análisis dispara "a ciegas". Por eso los scripts automáticos fallaron buscando servidores RPC o VMware donde no los había.

El Criterio del Profesional: Las herramientas automatizadas son "tontas" sin contexto humano. Un auditor real, al ver este bloqueo en Nmap, cambia su estrategia y pasa a usar herramientas especializadas para atacar capas web (como OWASP ZAP o Burp Suite o tabajos manuales).

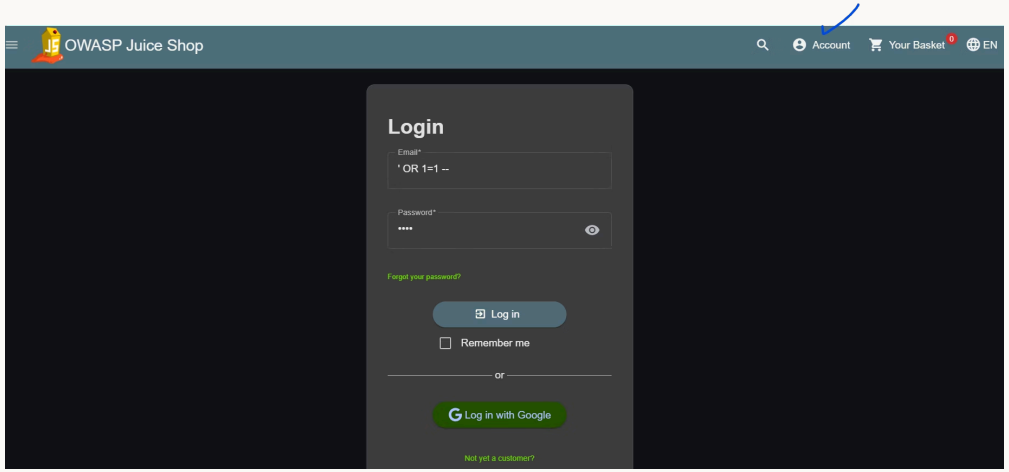
Cuando la herramienta no es suficiente, ejecutando un SQL Injectión

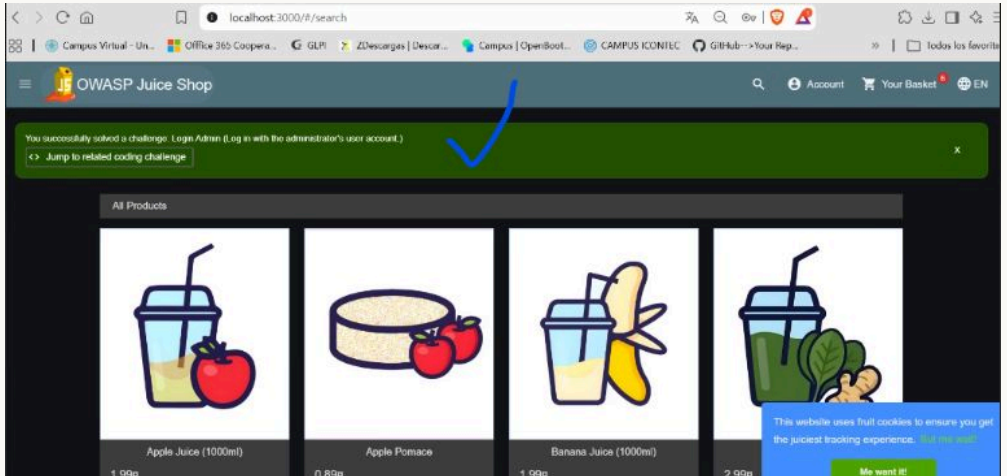
abran su navegador (`http://localhost:3000`), vayan a la sección de Login y apliquen el concepto de **Inyección SQL** que vimos la semana pasada.

Que sigan estos 3 pasos:

1. En el campo **Email**, que escriban exactamente esto: `' OR 1=1 --` *(Cierra el usuario con ', fuerza un acceso siempre verdadero con 1=1 y anula la contraseña con --)*
2. En el campo **Password**, que escriban cualquier cosa (ej. `12345`).
3. Clic en **Log in**.

El resultado: ¡El sistema va a colapsar, se saltarán la autenticación por completo y entrarán mágicamente como el usuario Administrador!





Conclusiónes y Próximos pasos

- **Ceguera en la Capa 7:** Nmap es el rey absoluto escaneando infraestructura y redes (Capas 3 y 4 del modelo OSI), pero es torpe analizando aplicaciones web modernas (Capa 7). No está diseñado para entender cómo funciona internamente una página web hecha en Node.js o React, por ello se requiere de otras tacticas manuales como SQL Injectión en este caso la cual tuvo Exito.
- **Ausencia de firmas (Banner Grabbing):** Para saber qué software corre en un puerto, Nmap espera que el servidor lo salude con una etiqueta visible (ej. "Hola, soy Apache v2.4"). Como Juice Shop es un contenedor moderno y silencioso, no envía esa firma. Al no recibir respuesta, Nmap se confunde, se rinde y lo etiqueta genéricamente como `ppp?`.
- **El error de los scripts (Efecto dominó):** Como la fase de reconocimiento falló y Nmap no sabía a qué se enfrentaba, el motor de vulnerabilidades (`--script vuln`) disparó a ciegas. Intentó ejecutar ataques diseñados para máquinas virtuales (VMware) y servicios de red antiguos (RPC) contra una página web, lo que provocó que los scripts se estrellaran y devolvieran esos errores.

Próxima clase: ¡Iniciamos el Momento 3! Semana 9: Técnicas de Ataque Avanzadas.

Prepárense para la Denegación de Servicio (DoS/DDoS) e interceptación Man in the Middle (MITM)